

Politique de mots de passe de l'entreprise

VerroulA · Kit de protection · septembre 2026

Le mot de passe reste la première clé d'accès à votre activité : messagerie, banque, comptabilité, fichiers clients. Cette politique fixe des règles simples, applicables dès demain dans une entreprise de 1 à 50 salariés. Vous pouvez l'adopter telle quelle et insérer la clause de règlement intérieur fournie en fin de document.

Pourquoi cette politique existe

La grande majorité des incidents de cybersécurité exploitent un facteur humain : un mot de passe faible, deviné, volé ou réutilisé d'un service à l'autre. Les attaquants ne forcent pas vos portes au hasard. Ils testent les identifiants qui circulent, les mots de passe courants et les comptes laissés sans protection.

Une politique de mots de passe ne supprime pas tous les risques. Elle rend votre entreprise plus difficile à atteindre que la moyenne des autres. Or un attaquant cherche la cible la plus simple. Votre meilleure défense est de ne pas être cette cible.

Les trois règles de base

1. La longueur prime sur la complexité. Chaque mot de passe professionnel compte au moins 12 caractères. Une phrase longue est plus sûre et plus facile à retenir qu'un mot court truffé de symboles.
2. Un mot de passe différent pour chaque service. Un même mot de passe sur dix services transforme un seul vol en dix intrusions.
3. La double authentification partout où elle est proposée. Un mot de passe volé ne suffit alors plus pour entrer. Il faut une deuxième preuve : code sur le téléphone, application d'authentification ou clé physique.

Comment construire un bon mot de passe

Une phrase de passe associe trois ou quatre mots sans lien évident. Exemple : « fourgon bleu voyage matin ». Elle se retient facilement et résiste bien mieux qu'un mot unique.

À éviter : votre prénom, la date de naissance, le nom de l'entreprise, les suites du clavier, les mots du dictionnaire utilisés seuls. À éviter aussi : prendre un mot court et lui ajouter un chiffre et un symbole pour faire « complexe ». La longueur compte plus que le symbole.

Si la mémorisation de plusieurs phrases de passe vous semble impossible, ne les notez pas sur un pense-bête. Utilisez le gestionnaire décrit ci-dessous : c'est exactement son rôle.

Le gestionnaire de mots de passe : un outil indispensable

Un gestionnaire de mots de passe est un coffre-fort numérique. Il crée des mots de passe longs et uniques pour chaque service, et les conserve derrière une seule clé : votre mot de passe maître.

Ce qu'il change concrètement :

- Plus besoin de mémoriser chaque mot de passe : le gestionnaire les saisit pour vous.
- Chaque compte reçoit un mot de passe unique, impossible à retenir par cœur et donc impossible à réutiliser ailleurs.
- Le mot de passe maître devient la seule chose à protéger : au moins 16 caractères, jamais écrit, jamais partagé.

Choisissez un gestionnaire reconnu et édité par un acteur établi (par exemple Bitwarden, 1Password ou KeePassXC). Prenez la formule professionnelle pour l'entreprise ou un coffre partagé. Quelques règles de fonctionnement :

- Un seul coffre professionnel pour toute l'entreprise, créé par le dirigeant.
- Chaque salarié n'accède qu'aux identifiants nécessaires à son poste.
- Les mots de passe personnels des salariés n'entrent jamais dans le coffre professionnel.
- Au départ d'un salarié, le dirigeant retire son accès au coffre le jour même.

Quand changer un mot de passe

Inutile de tout changer chaque trimestre par simple habitude : une rotation forcée sans raison pousse à choisir des mots de passe plus faibles, car personne ne mémorise dix mots de passe renouvelés sans cesse. Changez un mot de passe dans quatre cas précis :

1. Après une suspicion de compromission : message suspect, connexion étrange, alerte de sécurité de l'éditeur du service.
2. Au départ d'un salarié qui connaissait le compte concerné.
3. Après un incident de sécurité, même mineur.
4. À la prise de fonction, pour tout compte dont vous héritez d'un prédécesseur.

Le compte administrateur séparé

Le compte administrateur dispose de tous les pouvoirs : installer un logiciel, créer des comptes, modifier les paramètres de sécurité. Il ne doit jamais servir au travail courant.

Règles à appliquer :

- Le dirigeant ou le référent technique détient le compte administrateur. Un seul compte administrateur par service, pas un par salarié.
- Le travail quotidien se fait avec un compte utilisateur simple.
- Le mot de passe administrateur reste dans le coffre professionnel. Il ne se transmet jamais par messagerie.
- Sur les services en ligne (hébergement, nom de domaine, banque, messagerie), le compte propriétaire est réservé : les salariés qui doivent utiliser le service reçoivent un compte utilisateur,

pas les clés du propriétaire.

Ce qui est interdit

- Écrire son mot de passe sur un post-it, sous le clavier ou dans un carnet posé sur le bureau.
- Partager un mot de passe par courriel, SMS ou messagerie instantanée.
- Utiliser le même mot de passe pour un usage personnel et un usage professionnel.
- Confier son mot de passe à un collègue « juste pour aujourd'hui ».
- Répondre à un message qui demande son mot de passe. Aucune banque, aucun service légitime, aucun collègue ne demande un mot de passe par message.

Modèle de clause pour le règlement intérieur

À copier-coller et à adapter au nom de votre entreprise.

« Chaque salarié de [Nom de l'entreprise] est tenu de respecter la politique de sécurité informatique, et notamment les règles relatives aux mots de passe. Les mots de passe professionnels comptent au moins 12 caractères, sont propres à chaque service et ne sont jamais partagés, ni communiqués par messagerie, ni notés sur un support visible. L'usage du gestionnaire de mots de passe fourni par l'entreprise est obligatoire pour les comptes professionnels. La double authentification doit être activée sur tout service qui la propose. Les comptes professionnels sont strictement personnels : leur usage par un tiers, même ponctuel, est interdit. Tout mot de passe suspecté d'avoir été divulgué doit être changé immédiatement, et le fait signalé à [nom du référent sécurité]. Le manquement à ces règles expose le salarié à des sanctions disciplinaires, dans les conditions prévues par le règlement intérieur et le code du travail. »

Si votre règlement intérieur contient déjà une clause générale de sécurité, ajoutez ce paragraphe ou annexe la présente politique. Dans tous les cas, faites signer à chaque salarié un accusé de réception daté.

Qui fait quoi

- Le dirigeant : nomme un référent sécurité, crée le coffre professionnel, détient les comptes administrateurs, valide la présente politique.
- Le référent sécurité : applique la politique au quotidien, retire les accès en cas de départ, tient à jour la liste des comptes, aide les salariés à activer la double authentification.
- Chaque salarié : applique les règles, utilise le coffre professionnel, signale toute anomalie, change immédiatement un mot de passe suspect.

Le départ d'un salarié mérite une attention particulière. Désactivez ses comptes le jour même, pas à la fin du mois. C'est l'action la plus rentable de toute cette politique, et la plus souvent oubliée.

Passer à l'action cette semaine

1. Créez le coffre professionnel et enregistrez-y les mots de passe clés. (30 minutes)
2. Changez le mot de passe du compte administrateur de vos services principaux. (15 minutes)
3. Activez la double authentification sur la messagerie et la banque en ligne. (20 minutes)
4. Diffusez cette politique à l'équipe et faites signer les accusés de réception. (15 minutes)
5. Inscrivez au calendrier un créneau trimestriel de revue des accès. (10 minutes)

En résumé

- Un mot de passe professionnel fait au moins 12 caractères et n'est jamais réutilisé d'un service à l'autre.
- Le gestionnaire de mots de passe est l'outil obligatoire : il rend ces règles applicables sans effort de mémoire.
- La double authentification s'active sur tous les services qui la proposent, en commençant par la messagerie et la banque.
- Au départ d'un salarié, ses accès sont coupés le jour même. En cas de doute sur un mot de passe, on le change : on ne réfléchit pas.